

Assessment Tool-3

M. Kavya

192472370

ITA1407

Ethical Hacking

Question : 24

Introduction:

Ethical hacking is the practice of legally testing computer systems, networks and applications to identify security vulnerabilities before malicious attackers can exploit them.

Ethical hackers operate under a formal agreement with the client and are guided by principles such as authorization, confidentiality, integrity, professionalism & responsible disclosure. Their primary responsibility is to improve the security of an organization's system while complying with legal & ethical standards.

Ethical issues in the scenario:

The situation presents several ethical concerns:

- The ethical hacker is authorized only to perform technical security testing.
- The suspected scan lies outside the agreed scope of work.
- Consumers may be suffering financial or personal harm.
- The ethical hacker has a duty to maintain client confidentiality.
- The ethical hacker also has a professional responsibility to act with integrity & avoid enabling harmful or illegal activities.

Applications of Ethical Hacking Principles:

1) Authorization:

Authorization is the foundation of ethical hacking.

An ethical hacker must perform only those activities that are permitted by the client.

Application:

The contract allows security testing, not investigation into business operations. Conducting additional investigations without permission would violate professional ethics & may also breach the contract.

Evaluation:

The ethical hacker should not independently investigate the company's business practices beyond the authorized scope.

2) Scope of Engagement:

The scope of engagement clearly defines what systems, networks and activities can be tested.

Since the suspected scam relates to the company's business operations rather than cybersecurity, it falls outside the scope of penetration.

Evaluation:

The ethical hacker should continue only the approved security assessment while documenting any observations that are directly relevant to the findings.

3) Confidentiality :

Ethical hackers often access confidential information during security testing. Maintaining confidentiality is a fundamental ethical responsibility.

Disclosing sensitive information without authorization may violate legal agreements & damage the client's reputation unfairly.

Evaluation :

The ethical hacker should not publicly reveal confidential info unless disclosure is required by law.

4) Integrity :

Integrity requires ethical hackers to be honest, objective & unbiased.

The hacker should report only verified observations and avoid making accusations based on assumptions or incomplete evidence.

Evaluation :

Professional decisions should always be based on factual evidence rather than personal opinions.

5) Responsible Disclosure

Responsible disclosure means reporting security findings through appropriate channels instead of making public announcements.

The ethical hacker should prepare a professional report describing the observation & submit it to the authorized client representative or employee.

6) Legal compliance:

Ethical hackers must comply with all applicable laws & organized policies.

If clear evidence of illegal activities such as fraud, identity theft, or financial crimes is discovered, the hacker may have a legal responsibility to report the matter through appropriate authorities.

- Arguments Supporting Report :

Professional ethics support reporting the issue for several reasons.

Protection of Consumers:

If consumers are being deceived or financially harmed, reporting the issue may prevent further losses & protect the public.

Professional Integrity:

Ignoring credible evidence of wrongdoing may conflict with the ethical hacker's responsibility to act honestly & responsibly.

Legal Responsibility:

Certain laws require professionals to report evidence of serious criminal activities. Following legal procedures helps ensure compliance.

- Arguments against Immediate public Disclosure:

There are also valid reasons why the ethical hacker should not immediately expose the company.

Limited Technical Role:

The ethical hacker was hired only to evaluate cybersecurity, not to investigate financial or business operations.

Confidentiality Obligations:

The engagement likely includes confidentiality agreements that prohibit unauthorized disclosure.

Insufficient Evidence:

Reconnaissance may reveal suspicious information, but suspicion alone is not enough to prove fraud.

To Whom should the Ethical Hacker report?

The reporting process should follow professional ethics.

step-1:

Report the observations to the authorized client representative responsible for the engagement.

step-2:

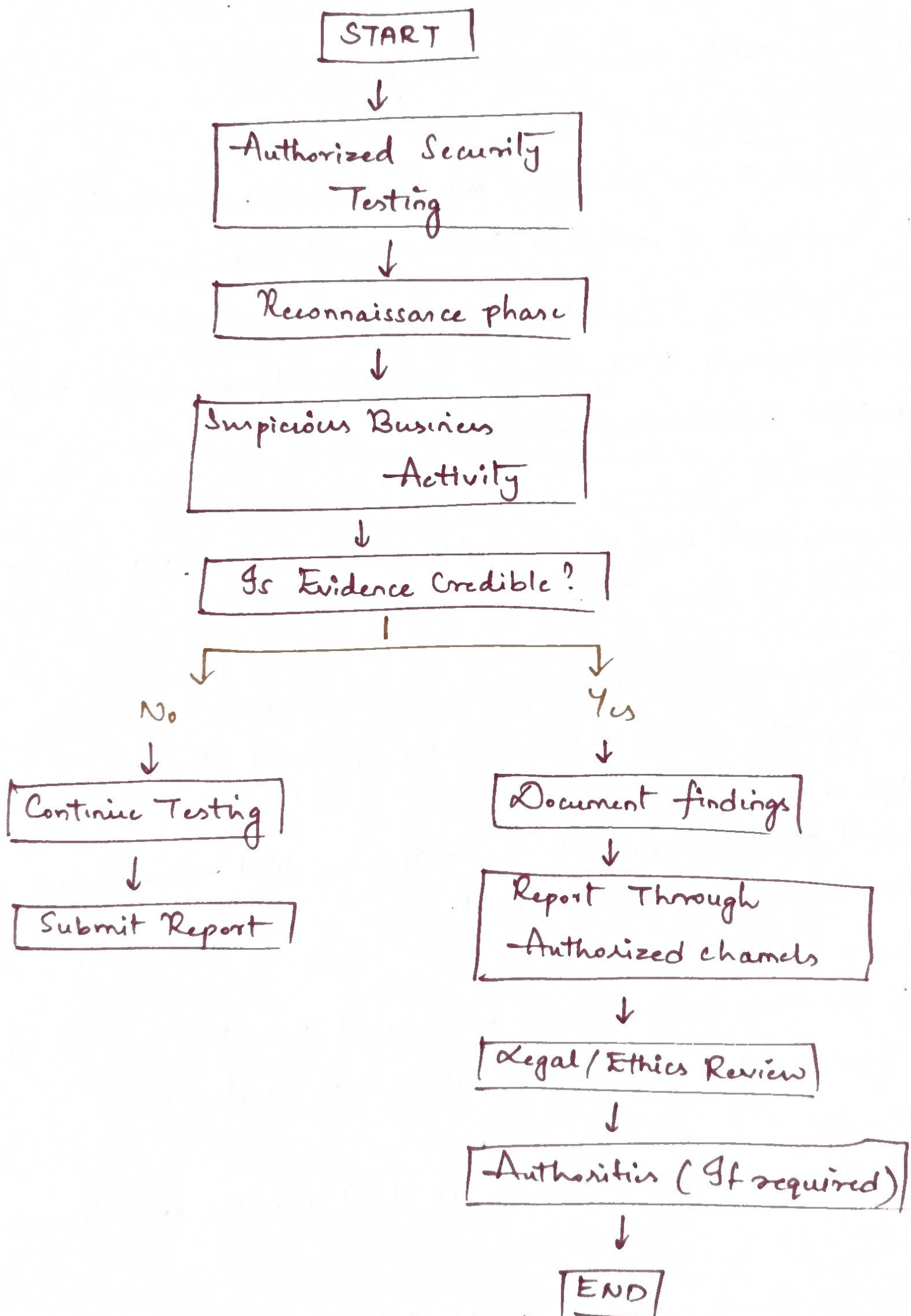
If the issues involves senior management or create a conflict of interest, escalate it to the ethical hacker's employers.

step-3:

If there is credible evidence of illegal activities & the law requires reporting.

Step-4: Avoid publishing confidential info on social media.

Flow Chart:



Ethical Decision :

The ethical hacker should not ignore credible evidence that consumers are being harmed.

The most ethical approach is to :

- Stay within the authorized scope
- Document factual observations
- Maintain confidentiality.
- Follow responsible disclosure.
- Report through authorized organizational or legal channels.